

Bill of Materials (BOM) et Suivi de Sécurité - TRACE & TRACE-SCAN

Date de mise à jour : Avril 2026

Applications : TRACE (Plateforme centrale) & TRACE-SCAN (Satellite mobile)

Objectif : Inventaire exhaustif des dépendances pour le suivi des vulnérabilités (CVE) et la maintenance préventive.

1. ENVIRONNEMENT SYSTÈME (OS)

Composant	Version Cible	Méthode d'installatio n	Rôle	Stratégie de mise à jour
Debian Linux	13 (Trixie)	Image système / ISO	Système d'exploitation hôte sécurisé.	apt-get update && apt-get upgrade réguliers (mensuel préconisé).

2. INFRASTRUCTURE & BACKEND (Serveur TRACE)

Composant	Version / Source	Méthode	Rôle	Suivi de sécurité
Nginx	Dépôts Debian 13	apt	Serveur Web (fichiers statiques) et Reverse Proxy (TLS, routage API).	Gestion automatique via apt. Surveiller les CVE Nginx.
PostgreSQL	v17 (Dépôts Debian)	apt	Base de données	Gestion automatique

			relationnelle. Gère l'auth (pgcrypto) et la logique métier (Triggers/RPC).	via apt. Surveiller les failles PostgreSQL.
PostgREST	v12.x (Binaire statique)	Copie manuelle (/usr/local/bin /)	Middleware API. Transforme le schéma SQL en API RESTful.	Manuel : Surveiller les releases sur le GitHub officiel de PostgREST.
OpenSSL	Dépôts Debian 13	apt	Génération des certificats TLS/SSL locaux.	Gestion automatique via apt.

3. FRONTEND - PLATEFORME CENTRALE (TRACE)

Composant	Version	Intégration	Rôle	Suivi de sécurité
Vanilla JS	N/A	Natif	Logique métier de l'application (app.js).	Revue de code interne (SAST). Focus sur escapeHTML().
DSFR	v1.14.3	Local (/dsfr/)	Système de Design de l'État (UI/UX, Accessibilité)	Surveiller le dépôt GitHub GouvernementFR/dsfr.
jsPDF	v2.5.1	Local (/utils/)	Génération	Mise à jour

			des Procès-Verbaux de mise au rebut (PDF).	manuelle du fichier dans /utils/ en cas de CVE.
jsPDF-AutoTable	v3.5.25	Local (/utils/)	Extension jsPDF pour les tableaux de données du PV.	Mise à jour manuelle du fichier dans /utils/.
QR Code Styling	v1.6.0-rc.1	CDN/Local	Rendu des planches d'étiquettes QR Codes personnalisés.	Surveiller le dépôt GitHub kozakdenys/qr-code-styling.

4. APPLICATION SATELLITE MOBILE (TRACE-SCAN)

L'application satellite est conçue pour le mode "Offline-First" (PWA), imposant l'hébergement local de toutes ses ressources.

Composant	Version	Intégration	Rôle	Suivi de sécurité
PWA Engine	HTML5/JS	Natif	Interface de scan et gestion des exports (index.html).	Revue de code interne.
Service Worker	v1.1	Natif (sw.js)	Gestion du cache et fonctionnement hors-ligne (Offline).	Revue de code interne.
html5-	v2.3.8 (ou +)	Local (/utils/)	Bibliothèque	Critique :

qrcode			de lecture des QR Codes via caméra mobile.	Surveiller les CVE sur mebjas/html5-qrcode.
DSFR (Light)	v1.14.3	Local	Identité visuelle (Header Marianne).	Cohérence avec l'application centrale.

5. PROCESSUS DE MAINTENANCE ET AUDIT

5.1. Veille sur les dépendances

Contrairement aux projets Node.js, TRACE n'utilise pas de package-lock.json. La veille doit donc être proactive :

- **Système** : Script instrace.sh à relancer sur des images Debian à jour.
- **Bibliothèques JS** : Les fichiers dans /utils/ et /dsfr/ doivent être remplacés manuellement si une vulnérabilité majeure est publiée (veille GitHub).

5.2. Sécurité du code source (Audit Statique)

- **Protection XSS** : L'utilisation de escapeHTML() dans app.js est obligatoire pour toute injection de données provenant de la base de données ou de l'utilisateur dans le DOM.
- **Intégrité PWA** : Le fichier manifest.json et le sw.js de TRACE-SCAN doivent être servis via HTTPS uniquement (garanti par la configuration Nginx).

5.3. Gestion du patrimoine logiciel

- **Licence** : Creative Commons (CC BY-NC-SA).
- **Dépôt** : GitHub (Public). Permet l'utilisation d'outils d'analyse automatique (type Dependabot ou CodeQL) même sur du code Vanilla JS.